



Tietoturva-auditoinnin palvelumallin suunnittelu ja testaus pk-yritykselle



Liis Eskola

Sisällysluettelo

1.	JOHDANTO	3
1.1.	HARJOITTELUN TAUSTA JA TARKOITUS	3
1.2.	MITÄ ON TIETOTURVA-AUDITOINTI?	3
1.3.	RAPORTIN RAKENNE	3
2.	AUDITOINNIN TAVOITE JA RAJAUS	4
2.1.	HARJOITTELUN TAVOITTEET	4
2.2.	RAJAUKSET	4
3.	VIITEKEHYKSET JA MALLIT	5
3.1.	TRAFICOM / KYBERTURVALLISUUSKESKUS – OHJEISTUKSET	5
3.2.	ISO/IEC 27001 JA 27002	5
3.3.	NIST CYBERSECURITY FRAMEWORK	5
4.	AUDITOINTISUUNNITELMA	6
4.1.	VAIHEISTUS JA MENETELMÄT	6
4.2.	TYÖKALUT (OPEN SOURCE JA KAUPALLISET VAIHTOEHDOT)	6
4.3.	AIKATAULU JA RESURSSIT	7
5.	CHECKLIST	8
5.1.	HALLINNOLLINEN JA TEKINEN CHECKLIST	8
6.	POC-YMPÄRISTÖN RAKENTAMINEN	8
6.1.	YMPÄRISTÖN SUUNNITTELU	8
6.2.	VIRTUAALIKONEET JA PALVELUT	9
6.3.	TOINEN VIRTUAALIKONE (SUUNNITTELU JA KÄYTTÖTARKOITUS)	9
6.4.	ASENNETUT TYÖKALUT	10
6.5.	YMPÄRISTÖN RAKENTAMINEN	11
6.6.	OPPIMISEN TUkena KÄYTETTY KURSSI	12
7.	TESTAUS JA TULOKSET	12
7.1.	SALASANAKÄYTÄNNÖT	12
7.2.	OHJELMISTOPÄIVITYKSET	13
7.3.	VERKKOTURVA (NMAP, OPENVAS)	14
7.3.1	Nmap-porttiskannaus	14
7.3.2	OpenVAS-haavoittuvuusskannerin käyttöönotto	17
7.4.	LYNIS-AUDITOINTI	20
7.5.	KÄYTTÖOIKEUDET	23
7.6.	LOKITUS JA VALVONTA	24
7.7.	VARAUTUMINEN KIRISTYSHAITTAOHJELMIIN	25
8.	ANALYYSI JA SUOSITUKSET	25
8.1.	LÖYDÖSTEN VERTAILU HALLINNOLLISIIN VAATIMUKSIIN	25
8.2.	KESKEISET VAHVUUDET JA PUUTTEET	26
	<i>Vahvuudet</i>	26
	<i>Puutteet ja kehityskohteet</i>	27
8.3.	SUOSITUKSET PK-YRITYKSILLE	27

9.	JOHTOPÄÄTÖKSET	28
9.1.	MITÄ OPIN	28
9.2.	PALVELUMALLIN HYÖDYT PK-YRITYKSELLE	29
9.3.	JATKKEHITYSMAHDOLLISUUDET	29
	LÄHTEET	30
	LIITTEET	30

1. Johdanto

1.1. Harjoittelun tausta ja tarkoitus

Tämä raportti on osa tradenomin tietojenkäsittelyn opintoihin kuuluvaa työharjoittelua. Harjoittelun aiheeksi valittiin tietoturva-auditoinnin prosessi pk-yritykselle, sillä tietoturva on sekä ajankohtainen että yritysten toiminnan jatkuvuuden kannalta keskeinen osa-alue. Harjoittelu toteutetaan koululle, eikä se kohdistu oikeaan yritykseen.

Harjoittelun tarkoituksena on perehtyä tietoturvan hallinnollisiin ja teknisiin käytäntöihin sekä soveltaa niitä harjoitusympäristössä (Proof of Concept, POC). Työn lopputuloksena syntyy vaiheittain etenevä palvelumalli, jota pk-yritys voisi hyödyntää oman tietoturvansa arvioinnissa ja kehittämisessä.

1.2. Mitä on tietoturva-auditointi?

Tietoturva-auditointi on järjestelmällinen prosessi, jonka avulla organisaation tietoturvaa arvioidaan. Auditointi voi sisältää sekä hallinnollisia tarkasteluja että teknisiä testejä. Hallinnollisessa auditoinnissa tarkastellaan esimerkiksi, onko organisaatiolla ajantasainen tietoturvapolitiikka, henkilöstölle järjestettyä koulutusta sekä selkeästi määritellyt vastuut tietoturva-asioissa.

Tekninen auditointi puolestaan keskittyy käytännön suojauskeinoihin, kuten ohjelmistopäivityksiin, käyttöoikeuksien hallintaan, varmuuskopiointiin ja verkon suojaamiseen. Auditoinnin tarkoituksena on tunnistaa vahvuudet ja puutteet sekä antaa kehitysehdotuksia, joiden avulla organisaation tietoturvaa voidaan parantaa.

1.3. Raportin rakenne

Raportti etenee vaiheittain siten, että aluksi esitellään harjoittelun tavoitteet, rajaukset ja käytettävät viitekehykset. Sen jälkeen kuvataan auditointisuunnitelma, joka sisältää menetelmät, työkalut ja aikataulun. Raportissa esitellään myös hallinnolliset ja tekniset checklistit, joiden avulla auditointia voidaan toteuttaa.

Käytännön osuudessa kuvataan rakennettu POC-ympäristö ja testauksen tulokset. Näiden pohjalta tehdään analyysi ja annetaan suosituksia pk-yrityksen näkökulmasta. Raportin lopuksi esitetään johtopäätökset, joissa pohditaan harjoittelun aikana opittuja asioita sekä palvelumallin hyötyjä pk-yrityksille. Liitteisiin on koottu hallinnollinen checklist, tekninen checklist, auditointisuunnitelma sekä viitekehysten kartoitus. Testitulokset on esitetty raportin testausosuudessa.

2. Auditoinnin tavoite ja raja

2.1. Harjoittelun tavoitteet

Tämän harjoittelun keskeisenä tavoitteena on perehtyä pk-yrityksen tietoturvan arviointiin sekä hallinnollisesta että teknisestä näkökulmasta. Harjoittelun aikana on tarkoitus oppia, miten tietoturvaa voidaan auditoida vaiheittain ja miten auditointiprosessi voidaan muuttaa palvelumalliksi, jota pk-yritys voisi hyödyntää omassa toiminnassaan.

Tavoitteisiin kuuluu:

- **Oppiminen.** Kehittää omaa osaamista tietoturvan auditointiprosesseista ja käytännön työkaluista.
- **Palvelumalli pk-yritykselle.** Rakentaa vaiheittainen malli, joka sisältää suunnittelun, toteutuksen, testauksen ja raportoinnin.
- **Työkalujen selvitys.** Kartoittaa ja kokeilla avoimen lähdekoodin tietoturvatyökaluja sekä tutustua kaupallisiin vaihtoehtoihin.
- **Käytännön harjoittelu.** Rakentaa harjoitusympäristö (POC), jossa testataan ja dokumentoidaan auditointiin liittyviä menetelmiä.
- **Raportointi.** Tuottaa dokumentaatio, joka kokoaa tulokset ja tarjoaa suosituksia pk-yrityksille.

2.2. Rajaukset

Auditointi toteutetaan koulun harjoitteluna, eikä se kohdistu oikeaan yritykseen. Tämän vuoksi auditoinnin sisältö ja raja

Mukana:

- Hallinnolliset käytännöt (tietoturvapolitiikat, henkilöstön koulutus, riskienhallinta)
- Tekninen suojaus (ohjelmistopäivitykset, käyttöoikeudet, verkkoturva, lokitus sekä varmuuskopioinnin arviointi)
- POC-ympäristön rakentaminen ja testaus avoimen lähdekoodin työkaluilla
- Työkalujen kartoitus ja arviointi

Ei mukana:

- Syvä penetraatiotestaus ja hyökkäyssimulaatiot (riskialtista ja vaatii erityistä osaamista)
- Tuotantoympäristöjen auditointi (harjoittelu rajoittuu simuloituun POC-ympäristöön)
- Fyysisen turvallisuuden tarkastukset (esim. tilojen kulunvalvonta, lukitukset)

- Lainsäädännön ja tietosuoja-asetusten yksityiskohtainen arviointi (huomioidaan vain yleisellä tasolla)

3. Viitekehykset ja mallit

Pk- yritysten tietoturva-auditointia varten on olemassa useita kansallisia ja kansainvälisiä viitekehyksiä, jotka tarjoavat ohjeita, käytäntöjä ja standardeja. Tässä työssä auditoinnin suunnittelussa hyödynnetään kolmea keskeistä viitekehystä: Traficom / Kyberturvallisuuskeskuksen ohjeistukset, ISO/IEC 27001 ja 27002 sekä NIST Cybersecurity Framework. Näiden avulla muodostetaan kokonaisvaltainen ja vaiheistettu malli, jota pk-yritys voi hyödyntää oman tietoturvan arvioinnissa.

3.1. Traficom / Kyberturvallisuuskeskus – ohjeistukset

Traficomin Kyberturvallisuuskeskus tarjoaa pk-yrityksille suunnattuja selkeitä ja käytännönläheisiä ohjeita tietoturvan kehittämiseen. Oppaissa painotetaan muun muassa ohjelmistopäivitysten ajantasaisuutta, varmuuskopioinnin toteuttamista ja testaamista, henkilöstön koulutusta, salasanaikäytäntöjä sekä käyttöoikeuksien hallintaa. Näitä ohjeistuksia voidaan hyödyntää erityisesti hallinnollisen auditoinnin pohjana sillä ne tarjoavat yksinkertaisia ja suomenkielisiä ohjeita, jotka soveltuvat pk-yritysten arkeen.

(Lähde: Traficom / Kyberturvallisuuskeskus, Tietoturvaopas pk-yrityksille)

3.2. ISO/IEC 27001 ja 27002

ISO/IEC 27001 on kansainvälinen standardi, joka määrittelee vaatimukset tietoturvan hallintajärjestelmälle. Se painottaa riskienhallintaa ja jatkuvaa parantamista, ja se soveltuu kaiken kokoisille organisaatioille. ISO/IEC 27002 puolestaan täydentää standardia tarjoamalla käytännön ohjeita ja kontrollipisteitä, kuten käyttöoikeuksien hallinta, henkilöstön turvallisuus, fyysisen ympäristön suojaaminen ja jatkuvuuden hallinta. Pk-yrityksille ISO-standardien hyöty on erityisesti siinä, että ne tarjoavat jäsennellyn mallin tietoturvan kehittämiseksi ja mahdollisuuden verrata omia käytäntöjä kansainvälisesti tunnustettuun viitekehykseen.

(Lähteet: ISO.org – ISO/IEC 27001 Information Security Management; BSI Group – What is ISO/IEC 27001?)

3.3. NIST Cybersecurity Framework

NIST Cybersecurity Framework (NIST CSF) on Yhdysvalloissa kehitetty ja kansainvälisesti tunnettu viitekehys, joka jäsentää kyberturvallisuuden viiteen päätoimintoon: Identify, Protect, Detect, Respond ja Recover. Kehys tarjoaa joustavan ja skaalautuvan mallin, jota voidaan soveltaa sekä suurissa että pienissä organisaatioissa.

Pk-yrityksille NIST CSF tarjoaa selkeän rakenteen, jonka avulla voidaan tunnistaa

riskit, suojata kriittisiä resursseja, havaita poikkeamat, reagoida hyökkäyksiin ja palautua niistä. Tämä tekee siitä erinomaisen työkalun käytännön auditointiin ja testauksen kohteiden määrittelyyn. (Lähteet: NIST Cybersecurity Framework; CISA – NIST CSF Overview)

4. Auditointisuunnitelma

4.1. Vaiheistus ja menetelmät

Auditointi toteutetaan vaiheittain sekä hallinnollisesta että teknisestä näkökulmasta. Hallinnollinen osuus sisältää viitekehysten kartoituksen ja checklistin laadinnan, joiden avulla voidaan arvioida pk-yrityksen tietoturvapoliittikkoja, koulutusta ja riskienhallintaa.

Tekninen osuus toteutetaan harjoitusympäristössä (POC), jossa testataan tietoturvakontrolleja käytännössä. Testaukset kohdistuvat seuraaviin osa-alueisiin:

- **Salasanakäytännöt ja käyttöoikeudet:** selvitetään, millaisia salasanoja järjestelmä hyväksyy ja onko käyttöoikeudet rajattu oikein.
- **Ohjelmistopäivitykset:** tarkistetaan, löytyykö asentamattomia päivityksiä ja onko automaattinen päivitys käytössä.
- **Varmuuskopiointi ja palautus:** huomioidaan auditoinnin tarkastuskohteena checklisten ja suositusten tasolla.
- **Verkkoturva:** suoritetaan porttiskannaus ja haavoittuvuustarkastelu avoimen lähdekoodin työkaluilla.
- **Lokitus ja valvonta:** tarkastellaan, kirjautuvatko epäonnistuneet kirjautumiset ja päivitykset lokiin.
- **Varautuminen kiristyshaittaohjelmiin:** arvioidaan varmuuskopiointikäytäntöjä, käyttöoikeuksien hallintaa ja muita keskeisiä suojaustoimia.

Auditointimenetelminä käytetään dokumenttien läpikäyntiä sekä teknistä testausta POC-ympäristössä.

4.2. Työkalut (Open Source ja kaupalliset vaihtoehdot)

Teknisessä testauksessa hyödynnetään ensisijaisesti avoimen lähdekoodin työkaluja, joilla voidaan toteuttaa porttiskannauksia, haavoittuvuustarkastuksia, verkkoliikenteen analysointia ja palvelinten peruskonfiguraation arviointia. Lisäksi hyödynnetään käyttöjärjestelmien sisäänrakennettuja lokien tarkastustyökaluja. Raportissa mainitaan myös muutamia kaupallisia vaihtoehtoja vertailun vuoksi, mutta varsinainen testaus toteutetaan avoimen lähdekoodin ratkaisulla.

Työkalu	Käyttötarkoitus	Lisenssi	Perustelu valinnalle
---------	-----------------	----------	----------------------

Nmap	Porttiskannaus ja palveluiden tunnistus	Open Source	Kevyt ja laajalti käytetty työkalu, soveltuu pk-yrityksen verkon näkyvyyden arviointiin.
OpenVAS (Greenbone)	Haavoittuvuusskannaus ja raportointi	Open Source	Tarjoaa kattavat haavoittuvuustietokannat ja soveltuu POC-ympäristöön ilman lisenssimaksuja.
Wireshark (Kartoitettiin osana työkaluvaihtoehtoja, mutta sitä ei käytetty varsinaisessa testauksessa.)	Verkkoliikenteen analysointi	Open Source	Yksi tunnetuimmista verkkoanalyysityökaluista, mahdollistaa liikenteen tarkastelun reaaliaikaisesti.
Lynis	Linux-järjestelmien tietoturvatarkastus	Open Source	Kevyt työkalu palvelinten ja työasemien peruskonfiguraation tarkastamiseen.
Lokien tarkastus (auth.log / Event Viewer)	Käyttäjien toimien ja järjestelmän tapahtumien seuranta	Sisäänrakennettu (ilmainen)	Mahdollistaa epäonnistuneiden kirjautumisten ja järjestelmän muutosten havaitsemisen.
Nessus (ei käytetä, vain esimerkki)	Haavoittuvuusskannaus	Commercial	Tunnettu kaupallinen työkalu. Mainitaan vertailun vuoksi, mutta tässä projektissa käytetään vain avoimen lähdekoodin ratkaisuja.

4.3. Aikataulu ja resurssit

Auditointi on jaettu kahteen päävaiheeseen:

1. **Hallinnollinen osuus:** viitekehysten kartoitus, auditointisuunnitelman laadinta, checklistien rakentaminen.
2. **Tekninen osuus:** POC-ympäristön rakentaminen, testaus, tulosten keruu ja analyysi.

Harjoittelun kokonaislaajuus on noin 400 tuntia, joista 200 tuntia kohdistuu hallinnolliseen valmisteluun ja 200 tuntia teknisen ympäristön rakentamiseen ja testaamiseen.

5. Checklist

Tietoturva-auditoinnissa yksi keskeisistä työkaluista on checklist, jonka avulla voidaan systemaattisesti arvioida, mitkä asiat ovat kunnossa ja mitkä vaativat kehittämistä. Checklistit jaettiin tässä työssä kahteen osaan hallinnollinen checklist ja tekninen checklist

5.1. Hallinnollinen ja tekninen checklist

- **Hallinnollinen checklist** keskittyy organisaation toimintatapoihin, politiikkoihin ja henkilöstön osaamiseen. Sen avulla arvioidaan esimerkiksi, onko yrityksellä kirjallinen tietoturvapolitiikka, toteutetaanko henkilöstön koulutuksia, onko varmuuskopiointikäytännöt dokumentoitu ja onko käyttöoikeuksien hallinta selkeästi määritelty.
- **Tekninen checklist** keskittyy käytännön toteutukseen ja järjestelmien suojaustasoon. Tässä työssä tekninen checklist laadittiin siten, että suuri osa kysymyksistä voidaan tarkastaa tai testata harjoitusympäristössä. Esimerkkejä teknisestä checklististä ovat: ohjelmistopäivitysten ajantasaisuus, salasanojen hallinta, verkon porttiskannaus, käyttöoikeuksien tarkastaminen ja lokitietojen kirjaantuminen.

Checklistien käyttö tuo auditointiin toistettavuutta ja vertailtavuutta. Yritys voi täyttää saman listan esimerkiksi vuosittain ja seurata, onko kehitystä tapahtunut. Tässä raportissa checklistit toimivat myös dokumentoinnin välineenä: hallinnollinen checklist osoittaa, mitä ohjetta ja käytäntöjä tulisi olla, ja tekninen checklist näyttää, mitä asioita on mahdollista testata harjoitusympäristössä.

Täydet checklistit löytyvät raportin liitteistä:

Liite 1: Hallinnollinen checklist

Liite 2: Tekninen checklist

6. POC-ympäristön rakentaminen

6.1. Ympäristön suunnittelu

POC-ympäristö rakennettiin erilliselle testikoneelle. Testikoneena käytettiin HP tietokonetta, jossa on AMD Ryzen 5 2500U -suoritin, 8 GB RAM-muistia. Virtuaaliympäristö toteutettiin VirtualBox-virtualisointiohjelmistolla.

POC-ympäristöön luotiin kaksi virtuaalikonetta: yksi palvelinympäristöä simuloiva Linux-järjestelmä sekä toinen testauskone, josta suoritettiin tietoturvatestit.

Ympäristön suunnittelussa huomioitiin, että testaus tapahtuu eristetyssä virtuaaliympäristössä, jolloin mahdolliset virheet tai tietoturvatestit eivät vaikuta oikeisiin järjestelmiin.

6.2. Virtuaalikoneet ja palvelut

POC-ympäristöön luotiin yksi Ubuntu Server 24.04 LTS -virtuaalikone, joka toimii palvelinympäristönä testaukselle.

Virtuaalikoneen asetukset:

- Käyttöjärjestelmä: Ubuntu Server 24.04 LTS
- Muisti: 2 GB RAM
- Prosessori: 1 CPU
- Levytila: 40 GB (VDI)
- Verkkotila: NAT (VirtualBoxin oletus)

Käyttöjärjestelmä asennettiin ISO-levykuvasta VirtualBoxin kautta. Asennuksen yhteydessä määriteltiin käyttäjätunnus ja salasana, joita käytetään järjestelmään kirjautumiseen.

Asennuksen jälkeen järjestelmään kirjauduttiin komentoriviltä (CLI), sillä Ubuntu Server ei sisällä graafista käyttöliittymää.

6.3. Toinen virtuaalikone (suunnittelu ja käyttötarkoitus)

Toinen virtuaalikone toimii harjoitusympäristössä auditoitavana kohdejärjestelmänä. Sen tarkoituksena on simuloida PK-yrityksen palvelinympäristöä, jonka tietoturvaa arvioidaan teknisen auditoinnin avulla.

Virtuaalikoneeseen asennetaan Ubuntu Server 24.04 LTS -käyttöjärjestelmä, joka toimii kevyenä ja yleisesti käytettynä palvelinalustana. Ympäristöön konfiguroidaan peruspalveluita, joiden avulla voidaan toteuttaa realistisia tietoturvatestauksia.

Virtuaalikoneeseen asennetaan seuraavat keskeiset palvelut:

- OpenSSH Server, joka mahdollistaa etäyhteydet palvelimeen
- Web-palvelin (Apache), jonka avulla voidaan simuloida julkista verkkopalvelua

Näiden palveluiden avulla voidaan arvioida palvelimen verkkonäkyvyyttä, avoimia portteja sekä palveluiden tunnistettavuutta.

Virtuaalikone toimii teknisen auditoinnin kohteena, jossa testataan erityisesti seuraavia osa-alueita:

- avoimien porttien ja palveluiden tunnistaminen
- järjestelmän päivitysten ajantasaisuus
- käyttöoikeuksien hallinta
- lokitus ja valvonta
- haavoittuvuuksien tunnistaminen ja kartoitus

Auditointi suoritetaan toiselta virtuaalikoneelta käsin (VM1), joka toimii auditointityökalujen käyttöympäristönä.

Ympäristö rakennetaan eristettyyn virtuaaliverkkoon, jotta testaus ei vaikuta muihin järjestelmiin ja voidaan turvallisesti suorittaa tietoturvatestauksia.

6.4. Asennetut työkalut

POC-ympäristöön asennettiin ja konfiguroitiin seuraavat keskeiset työkalut:

OpenSSH Server:

- Mahdollistaa etäyhteydet palvelimeen (SSH)
- Asennus tarkistettiin komennolla: `sudo apt install openssh-server -y`
- Palvelu käynnistettiin: `sudo systemctl start ssh`
- Toiminta varmistettiin: `systemctl status ssh`

Järjestelmäpäivitykset:

- Päivitykset haettiin ja asennettiin: `sudo apt update` ja `sudo apt upgrade -y`

Näiden avulla varmistettiin, että järjestelmä on ajantasainen ja valmis teknistä auditointia varten.

Seuraavassa vaiheessa ympäristöön tullaan asentamaan auditointityökaluja, kuten Nmap, Lynis ja OpenVAS.

6.5. Ympäristön rakentaminen

POC-ympäristön rakentamisen jälkeen suoritettiin ensimmäiset tekniset testit verkon toimivuuden ja palveluiden saavutettavuuden varmistamiseksi.

Virtuaalikoneiden välinen verkkoyhteys varmistettiin siten, että koneet pystyivät kommunikoimaan keskenään eristetyssä verkossa. Yhteys testattiin ping-komennolla, jolla varmistettiin, että kohdejärjestelmä vastaa verkossa.

Verkon toiminnan varmistamisen jälkeen kohdejärjestelmään (VM2) asennettiin keskeiset palvelut:

- OpenSSH Server (portti 22)
- Apache Web Server (portti 80)

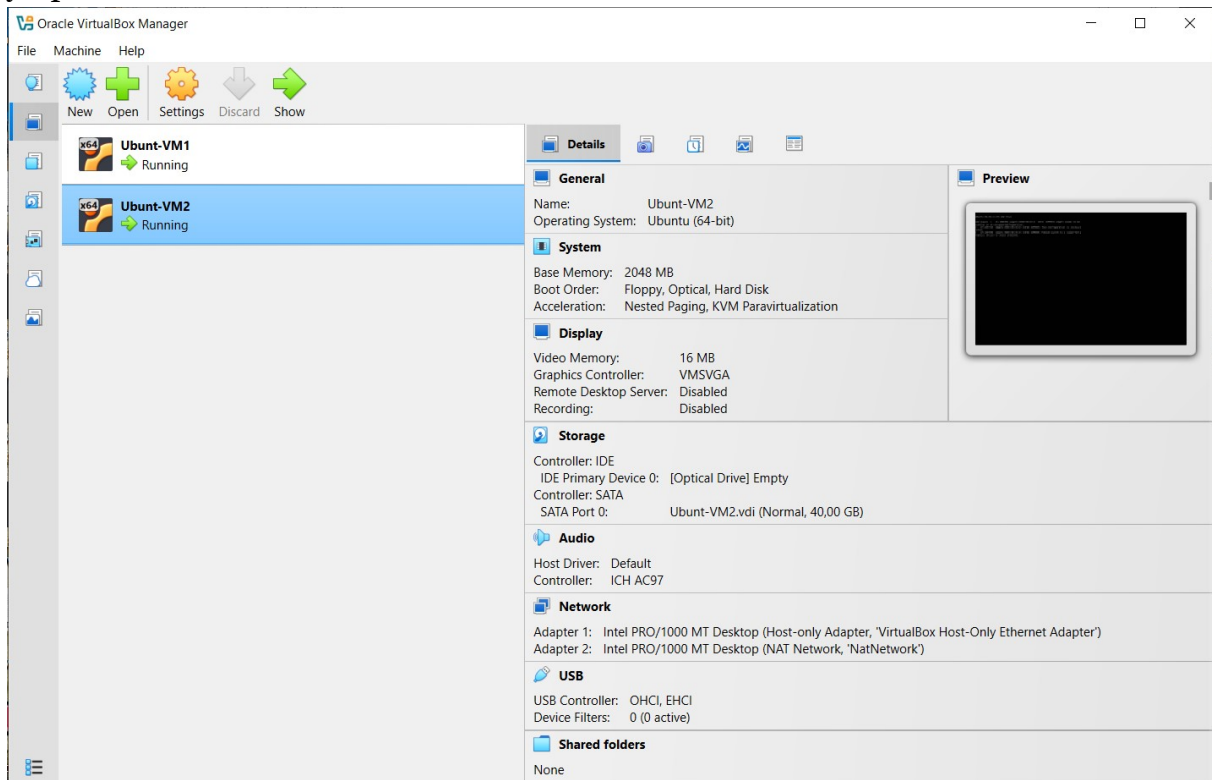
Tämän jälkeen suoritettiin ensimmäinen porttiskannaus Nmap-työkalulla auditointikoneelta (VM1). Skannauksen tuloksena havaittiin seuraavat avoimet portit:

- TCP 22 (SSH)
- TCP 80 (HTTP)

Skannauksessa ei havaittu muita avoimia portteja, mikä viittaa siihen, että järjestelmässä ei ole tarpeettomia palveluita käynnissä.

Tulokset osoittavat, että ympäristö on konfiguroitu onnistuneesti ja soveltuu teknisen auditoinnin jatkovaiheisiin, kuten palveluiden tarkempaan analysointiin ja haavoittuvuuksien tunnistamiseen.

Kuva 1. POC-ympäristön kaksi Ubuntu-virtuaalikonetta käynnissä VirtualBox-ympäristössä.



6.6. Oppimisen tukena käytetty kurssi

POC-ympäristön suunnittelua ja toteutusta varten hyödynnettiin Build a Cybersecurity Homelab: A Practical Guide to Offense + Defense -verkkokurssia (ProjectSecurity, Teachable). Kurssin avulla perehdyttiin käytännönläheisesti muun muassa VirtualBox-virtualisointiin, Linuxin perusteisiin, Active Directory -ympäristön rakentamiseen sekä puolustusratkaisuihin, kuten Security Onion ja Wazuh.

Kurssi esitteli vaiheittain, miten niin sanottu homelab- eli harjoitusympäristö voidaan rakentaa kyberturvallisuuden harjoittelua varten. Kurssin sisältöä hyödynnettiin muistiinpanojen ja testauksen suunnittelun muodossa, ja se tarjosi konkreettisia ideoita POC-ympäristön rakentamiseen tässä työssä.

7. Testaus ja tulokset

7.1. Salasanakäytännöt

Salasanakäytäntöjen tarkoituksena on estää heikkojen salasanojen käyttö sekä vähentää luvattoman käytön riskiä. Auditoinnissa tarkasteltiin Ubuntu Server -järjestelmän käyttäjätilejä sekä salasanakäytäntöihin liittyviä asetuksia.

Testauksessa luotiin käyttäjätunnus ja määritettiin sille salasana. Lisäksi tarkasteltiin järjestelmän PAM-asetuksia sekä Lynis-auditoinnin havaintoja salasanaturvallisuudesta.

Tulosten perusteella järjestelmä hyväksyi käyttäjälle määritetyn salasanan, mutta Lynis suositteli salasanojen vahvuusvaatimusten tiukentamista sekä PAM-salasananhallinnan käyttöönottoa. Tämä osoittaa, että järjestelmän perustason suojaus oli käytössä, mutta lisätoimenpiteillä salasanojen turvallisuutta voitaisiin parantaa.

Salasanojen hallinta on keskeinen osa tietoturvaa, sillä heikot tai helposti arvattavat salasanat ovat edelleen yksi yleisimmistä tietomurtojen syistä.

7.2. Ohjelmistopäivitykset

Yksi teknisen auditoinnin osa-alueista oli käyttöjärjestelmän päivitysten tarkastaminen. Päivitysten tarkoituksena on korjata tunnettuja haavoittuvuuksia, parantaa järjestelmän vakautta sekä vähentää tietoturvariskejä.

Testiympäristössä käytettiin Ubuntu Server 24.04 LTS -käyttöjärjestelmää. Päivitysten tila tarkistettiin komentoriviltä suorittamalla seuraavat komennot:

```
sudo apt update ja sudo apt upgrade -y
```

Komentojen avulla haettiin uusimmat pakettitiedot ohjelmistovarastoista sekä asennettiin saatavilla olevat päivitykset. Päivitysten asentamisen jälkeen järjestelmän tila tarkistettiin uudelleen.

Tulosten perusteella käyttöjärjestelmä oli ajan tasalla eikä järjestelmään jäänyt asentamattomia tietoturvapäivityksiä. Lisäksi järjestelmä ilmoitti, ettei palveluita tai ytimen osia tarvinnut käynnistää uudelleen päivitysten jälkeen.

Päivitysten hallinta on yksi tärkeimmistä tietoturvan perustoimenpiteistä, sillä suuri osa tietomurroista hyödyntää tunnettuja haavoittuvuuksia, joihin korjaukset ovat jo saatavilla. Testitulosten perusteella kohdejärjestelmän päivityskäytännöt olivat tässä vaiheessa kunnossa.

Kuva 2. Ubuntu Serverin päivitysten tarkistus ja järjestelmän tila päivitysten jälkeen.

```

Processing triggers for man-db (2.12.0-4ubuntu102) ...
Processing triggers for libc-bin (2.39-0ubuntu8.7) ...
Scanning processes...
Scanning linux images...

Running kernel seems to be up-to-date.
No services need to be restarted.
No containers need to be restarted.
No user sessions are running outdated binaries.
No VM guests are running outdated hypervisor (qemu) binaries on this host.
testiserver@testiserver:~$ nmap 192.168.56.102
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-23 15:32 UTC
Nmap scan report for 192.168.56.102
Host is up (0.00100s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 4.06 seconds
testiserver@testiserver:~$ nmap -sV 192.168.56.102
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-23 19:51 UTC
Nmap scan report for 192.168.56.102
Host is up (0.00068s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.38 seconds
testiserver@testiserver:~$

```

7.3. Verkkoturva (Nmap, OpenVAS)

7.3.1 Nmap-porttiskannaus

Verkkoturvan arviointia varten kohdejärjestelmälle suoritettiin useita Nmap-skannauksia. Nmap on avoimen lähdekoodin verkkoskanneri, jonka avulla voidaan tunnistaa verkossa olevia laitteita, avoimia portteja sekä käytössä olevia palveluita ja niiden versioita.

Testauksen tavoitteena oli selvittää, mitä palveluita kohdejärjestelmä tarjoaa verkkoon sekä arvioida, onko järjestelmässä näkyvissä tarpeettomia tai mahdollisesti riskialttiita palveluita.

Ensimmäisessä vaiheessa suoritettiin perusporttiskannaus kohdejärjestelmän IP-osoitteeseen: `nmap 192.168.56.102`

Skannauksen perusteella järjestelmä vastasi verkossa ja siitä havaittiin kaksi avointa porttia:

TCP 22 (SSH) ja TCP 80 (HTTP)

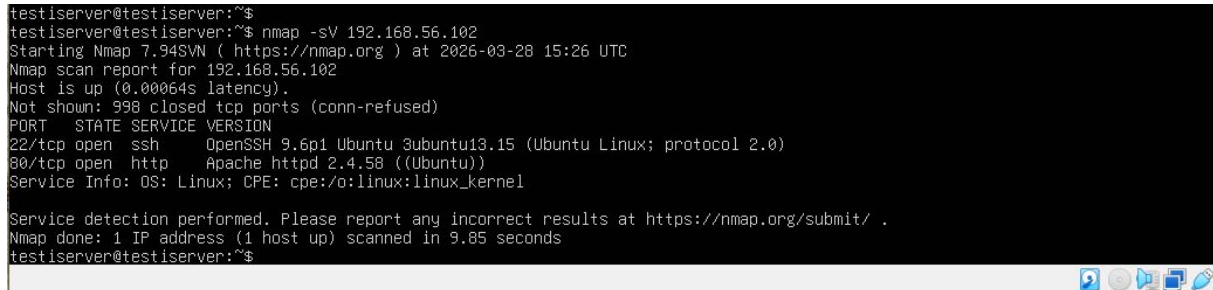
Muut yleisesti tarkastellut portit olivat suljettuja.

Seuraavaksi suoritettiin palveluiden versiotunnistus:

`nmap -sV 192.168.56.102`

Tulosten perusteella portissa 22 oli käytössä OpenSSH 9.6p1 ja portissa 80 Apache HTTP Server 2.4.58. Palveluiden tunnistaminen mahdollistaa käytössä olevien ohjelmistoversioiden vertaamisen tunnettuja haavoittuvuuksia sisältäviin versioihin.

Kuva 3. Nmap-palvelu- ja versiokartoitus kohdejärjestelmälle.



```
testiserver@testiserver:~$  
testiserver@testiserver:~$ nmap -sV 192.168.56.102  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-28 15:26 UTC  
Nmap scan report for 192.168.56.102  
Host is up (0.00064s latency).  
Not shown: 998 closed tcp ports (conn-refused)  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 9ubuntu13.15 (Ubuntu Linux; protocol 2.0)  
80/tcp    open  http      Apache httpd 2.4.58 ((Ubuntu))  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 9.85 seconds  
testiserver@testiserver:~$
```

Tämän jälkeen suoritettiin kattavampi porttiskaus:

```
nmap -p- -sV 192.168.56.102
```

Skannaus tarkasti kaikki TCP-portit. Tulosten perusteella järjestelmässä ei ollut avoinna muita palveluita kuin SSH ja Apache. Tämä viittaa siihen, että palvelimessa ei ollut tarpeettomia verkkopalveluita käytössä.

Lopuksi suoritettiin Nmapin laajempi tunnistusskannaus:

```
nmap -A 192.168.56.102
```

Tämän skannauksen avulla saatiin lisätietoa kohdejärjestelmästä. Nmap tunnisti käyttöjärjestelmän Linux-pohjaiseksi palvelimeksi, keräsi SSH-palvelimen avaintiedot sekä tunnisti Apache-palvelimen oletussivun. Lisäksi skannauksessa havaittiin palvelimelle luotu /company/-hakemisto, joka näkyi verkkopalvelun kautta.

Kuva 4. Nmapin laajennettu tunnistusskannaus (-A).

```
testiserver@testiserver:~$ nmap -sV 192.168.56.102
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-28 15:26 UTC
Nmap scan report for 192.168.56.102
Host is up (0.00064s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.85 seconds
testiserver@testiserver:~$ nmap -p- -sV 192.168.56.102
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-28 15:28 UTC
Nmap scan report for 192.168.56.102
Host is up (0.00062s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.80 seconds
testiserver@testiserver:~$ nmap -A 192.168.56.102
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-28 15:30 UTC
Nmap scan report for 192.168.56.102
Host is up (0.00082s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_  256 45:d2:4b:ad:35:13:08:80:98:e4:89:9d:80:60:f0:38 (ECDSA)
|_  256 d3:92:10:48:8b:f7:29:89:0d:3a:4c:a1:12:f5:ca:e8 (ED25519)
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
|_ _http-server-header: Apache/2.4.58 (Ubuntu)
|_ _http-title: Apache2 Ubuntu Default Page: It works
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.49 seconds
testiserver@testiserver:~$
```

Haavoittuvuuksien kartoitusta laajennettiin Nmapin skriptiominaisuuksien avulla. Skannaus tuotti useita tunnettuja CVE-viittauksia käytössä oleviin ohjelmistoversioihin liittyen sekä tunnisti verkkopalvelusta kiinnostavia kohteita jatkotarkastelua varten.

Tuloksissa havaittiin esimerkiksi Apache-palvelimeen liittyviä tunnettuja haavoittuvuustietueita sekä /company/-hakemisto, joka oli verkkopalvelun kautta saavutettavissa.

Kuva 5. Nmap-skriptiskannauksen tuloksia ja havaittuja CVE-viittauksia.

```

23079A70-8B37-56D2-9D37-F638EBF7F8B5 8.1 https://vulners.com/githubexploit/23079A70-8B37-56D2-9D37-F638EBF7F8B5 *EXPLOIT*
CVE-2025-59775 7.5 https://vulners.com/cve/CVE-2025-59775
CVE-2025-55753 7.5 https://vulners.com/cve/CVE-2025-55753
CVE-2025-53020 7.5 https://vulners.com/cve/CVE-2025-53020
CVE-2025-49630 7.5 https://vulners.com/cve/CVE-2025-49630
CVE-2024-47252 7.5 https://vulners.com/cve/CVE-2024-47252
CVE-2024-43394 7.5 https://vulners.com/cve/CVE-2024-43394
CVE-2024-43204 7.5 https://vulners.com/cve/CVE-2024-43204
CVE-2024-42516 7.5 https://vulners.com/cve/CVE-2024-42516
CVE-2024-39573 7.5 https://vulners.com/cve/CVE-2024-39573
CVE-2024-38477 7.5 https://vulners.com/cve/CVE-2024-38477
CVE-2024-38472 7.5 https://vulners.com/cve/CVE-2024-38472
CVE-2024-27316 7.5 https://vulners.com/cve/CVE-2024-27316
CNVD-2025-30837 7.5 https://vulners.com/cnvd/CNVD-2025-30837
CNVD-2025-30836 7.5 https://vulners.com/cnvd/CNVD-2025-30836
CNVD-2025-16614 7.5 https://vulners.com/cnvd/CNVD-2025-16614
CNVD-2025-16613 7.5 https://vulners.com/cnvd/CNVD-2025-16613
CNVD-2025-16612 7.5 https://vulners.com/cnvd/CNVD-2025-16612
CNVD-2025-16609 7.5 https://vulners.com/cnvd/CNVD-2025-16609
CNVD-2025-16608 7.5 https://vulners.com/cnvd/CNVD-2025-16608
CNVD-2025-16603 7.5 https://vulners.com/cnvd/CNVD-2025-16603
CNVD-2024-36393 7.5 https://vulners.com/cnvd/CNVD-2024-36393
CNVD-2024-36390 7.5 https://vulners.com/cnvd/CNVD-2024-36390
CNVD-2024-36389 7.5 https://vulners.com/cnvd/CNVD-2024-36389
CNVD-2024-20839 7.5 https://vulners.com/cnvd/CNVD-2024-20839
CDC791CD-A414-5ABE-A897-7CFA3C2D3D29 7.5 https://vulners.com/githubexploit/CDC791CD-A414-5ABE-A897-7CFA3C2D3D29 *EXPLOIT*
45D138AD-BEC6-552A-91EA-8816914CA7F4 7.5 https://vulners.com/githubexploit/45D138AD-BEC6-552A-91EA-8816914CA7F4 *EXPLOIT*
0E08753E-C6D7-5E76-A61F-6CA6F7F87AA8 7.5 https://vulners.com/githubexploit/0E08753E-C6D7-5E76-A61F-6CA6F7F87AA8 *EXPLOIT*
CVE-2025-49812 7.4 https://vulners.com/cve/CVE-2025-49812
CVE-2023-38709 7.3 https://vulners.com/cve/CVE-2023-38709
CNVD-2024-36395 7.3 https://vulners.com/cnvd/CNVD-2024-36395
CVE-2025-65082 6.5 https://vulners.com/cve/CVE-2025-65082
CNVD-2025-30833 6.5 https://vulners.com/cnvd/CNVD-2025-30833
CVE-2024-24795 6.3 https://vulners.com/cve/CVE-2024-24795
CNVD-2024-36394 6.3 https://vulners.com/cnvd/CNVD-2024-36394
CVE-2025-66200 5.4 https://vulners.com/cve/CVE-2025-66200
CVE-2024-36387 5.4 https://vulners.com/cve/CVE-2024-36387
CNVD-2025-30835 5.4 https://vulners.com/cnvd/CNVD-2025-30835
CNVD-2024-36392 5.4 https://vulners.com/cnvd/CNVD-2024-36392
_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
_ http-dombased-xss: Couldn't find any DOM based XSS.
_ http-csrf: Couldn't find any CSRF vulnerabilities.
_ http-server-header: Apache/2.4.58 (Ubuntu)
_ http-enum:
_ /company/: Potentially interesting folder
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 41.67 seconds
testiserver@testiserver:~$

```

Nmap-skannausten perusteella kohdejärjestelmän verkkonäkyvyys oli rajattu kahteen tarkoituksellisesti käyttöön otettuun palveluun (SSH ja Apache). Tarpeettomia avoimia portteja ei havaittu. Palveluiden versiot pystyttiin tunnistamaan onnistuneesti, mikä mahdollisti niiden vertaamisen tunnettuja haavoittuvuuksia sisältäviin ohjelmistoversioihin.

Tulokset osoittivat, että Nmap soveltuu hyvin pk-yrityksen tietoturva-auditoinnin ensimmäiseksi kartoitusvaiheeksi, sillä sen avulla voidaan nopeasti tunnistaa verkossa näkyvät palvelut sekä mahdolliset jatkotutkimusta vaativat kohteet.

7.3.2 OpenVAS-haavoittuvuusskannerin käyttöönotto

Nmap-skannauksen jälkeen auditointikoneelle asennettiin OpenVAS (Greenbone Vulnerability Manager) -haavoittuvuusskanneri. Työkalun tarkoituksena on tunnistaa järjestelmien tunnettuja haavoittuvuuksia ja virheellisiä määrittämiä. Käyttöönotto suoritettiin Ubuntu-palvelimella käyttäen GVM-pakettia.

Kuva 6. OpenVAS (GVM) -haavoittuvuusskannerin asennus auditointikoneelle.



Kuva 8. OpenVAS-järjestelmän toiminnan tarkistus gvm-check-setup -komennolla.

```

gvm-check-setup 23.11.0
Test completeness and readiness of GVM-23.11.0
Step 1: Checking OpenVAS (Scanner)...
  OK: OpenVAS Scanner is present in version 22.7.9.
  OK: Notus Scanner is present in version 22.6.2.
  OK: Server CA Certificate is present as /var/lib/gvm/CA/servercert.pem.
Checking permissions of /var/lib/openvas/gnupg/*
  OK: _gvm owns all files in /var/lib/openvas/gnupg/*
  OK: redis-server is present.
  OK: scanner (db_address setting) is configured properly using the redis-server socket: /var/run/redis-openvas/redis-server.sock
  OK: the mqtt_server_uri is defined in /etc/openvas/openvas.conf
  OK: _gvm owns all files in /var/lib/openvas/plugins
  OK: NVT collection in /var/lib/openvas/plugins contains 95089 NVTs.
  OK: The notus directory /var/lib/notus/products contains 517 NVTs.
Checking that the obsolete redis database has been removed
  OK: No old Redis DB
  OK: ospd-openvas service is active.
  OK: ospd-OpenVAS is present in version 22.6.2.
Step 2: Checking GVM Manager ...
  OK: GVM Manager (gvm) is present in version 23.1.0.
Step 3: Checking Certificates ...
  OK: GVM client certificate is valid and present as /var/lib/gvm/CA/clientcert.pem.
  OK: Your GVM certificate infrastructure passed validation.
Step 4: Checking data ...
  OK: SCAP data found in /var/lib/gvm/scap-data.
  OK: CERT data found in /var/lib/gvm/cert-data.
Step 5: Checking PostgreSQL DB and user ...
  OK: PostgreSQL version and default port are OK.
  gvm | _gvm | UTF8 | libc | en_US.UTF-8 | en_US.UTF-8 |
16440|pg-gvm|10|2200f|22.6|
  OK: At least one user exists.
Step 6: Checking Greenbone Security Assistant (GSA) ...
  OK: Greenbone Security Assistant is present in version 22.08.0"git.
Step 7: Checking if GVM services are up and running ...
  OK: gvm service is active.
  OK: gsad service is active.
Step 8: Checking few other requirements...
  OK: nmap is present.
  OK: ssh-keygen found, LSC credential generation for GNU/Linux targets is likely to work.
  OK: nsis found, LSC credential package generation for Microsoft Windows targets is likely to work.
  OK: xsltproc found.
  WARNING: Your password policy is empty.
  SUGGEST: Edit the /etc/gvm/pwpolicy.conf file to set a password policy.
Step 9: Checking greenbone-security-assistant...
  WARNING: the package greenbone-security-assistant is not installed
  FIX: install the package greenbone-security-assistant (available in non-free)

It seems like your GVM-23.11.0 installation is OK.
testiserver@testiserver:~$

```

7.4. Lynis-auditointi

Lynis on avoimen lähdekoodin tietoturva-auditointityökalu, joka on suunniteltu erityisesti Linux- ja Unix-pohjaisten käyttöjärjestelmien tietoturvan arviointiin. Työkalu tarkastaa järjestelmän asetuksia, käyttöoikeuksia, palveluita, ohjelmistopaketteja sekä järjestelmän kovennukseen liittyviä asetuksia.

Tässä harjoittelussa Lynistä käytettiin Ubuntu Server 24.04 LTS -palvelimen tietoturva-asetusten arviointiin. Auditointi suoritettiin seuraavalla komennolla:

```
sudo lynis audit system
```

Auditoinnin tavoitteena oli tunnistaa mahdollisia tietoturvapoikkeamia, virheellisiä asetuksia sekä järjestelmän koventamiseen liittyviä kehityskohteita.

Auditoinnin tuloksena Lynis havaitsi useita tarkastettavia kohteita sekä kehitysehdotuksia. Työkalu raportoi kaksi varsinaista varoitusta sekä useita suosituksia järjestelmän turvallisuuden parantamiseksi.

Kuva 9. Lynis-auditoinnin havaitsemat varoitukset.

```

ESC[1;37mESC[0m Show details of a test (lynis show details TEST-ID)
ESC[1;37mESC[0m Check the logfile for all details (less /var/log/lynis.log)
ESC[1;37mESC[0m Read security controls texts (https://cisofy.com)
ESC[1;37mESC[0m Use --upload to upload data to central system (Lynis Enterprise users)

=====
ESC[1;37mLynis security scan detailsESC[0m:

ESC[0;36mHardening indexESC[0m : ESC[1;37m57ESC[0m ESC[1;33m#####ESC[0m ]
ESC[0;36mTests performedESC[0m : ESC[1;37m257ESC[0m
ESC[0;36mPlugins enabledESC[0m : ESC[1;37m1ESC[0m

ESC[1;37mComponentsESC[0m:
- Firewall ESC[1;32mESC[0m
- Malware scanner ESC[1;31mESC[0m

ESC[1;33mScan modeESC[0m:
Normal [V] Forensics [ ] Integration [ ] Pentest [ ]

ESC[1;33mLynis modulesESC[0m:
- Compliance status ESC[1;33mESC[0m
- Security audit ESC[1;32mESC[0m
- Vulnerability scan ESC[1;32mESC[0m

ESC[1;33mFilesESC[0m:
- Test and debug information : ESC[1;37m/var/log/lynis.logESC[0m
- Report data : ESC[1;37m/var/log/lynis-report.datESC[0m

=====
ESC[1;37mLynisESC[0m 3.0.9

Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)

2007-2021, CISOfy - https://cisofy.com/lynis/
ESC[1;37mEnterprise support available (compliance, plugins, interface and tools)ESC[0m

=====
ESC[0;44m[TIP]ESC[0m: ESC[0;94mEnhance Lynis audits by adding your settings to custom.prfl (see /etc/lynis/default.prfl for all settings)ESC[0m

student@vm2:~$ grep -i warning lynis.txt
- Permissions for directory: /etc/sudoers.d [ WARNING ]
- Checking vulnerable packages [ WARNING ]
- Checking for empty ruleset [ WARNING ]
[WARNING]: Test CRYPT-7902 had a long execution: 15.193042 seconds
Warnings (2):
student@vm2:~$

```

Varoitukset liittyivät erityisesti seuraaviin osa-alueisiin:

- /etc/sudoers.d -hakemiston käyttöoikeuksien tarkastamiseen
- mahdollisesti haavoittuvien ohjelmistopakettien tarkistamiseen
- palomuurisääntöjen tarkastamiseen

Lynis ei raportoinut kriittisiä haavoittuvuuksia, mutta nosti esiin useita kehityskohteita, jotka voisivat parantaa järjestelmän tietoturva.

Kuva 10. Lynis-auditoinnin kehitysehdotuksia järjestelmän koventamista varten.

```

ESC[1;33mScan modeESC[0m:
Normal [V] Forensics [ ] Integration [ ] Pentest [ ]

ESC[1;33mLynis modulesESC[0m:
- Compliance status      ESC[1;33m?ESC[0m
- Security audit         ESC[1;32mVESC[0m
- Vulnerability scan     ESC[1;32mVESC[0m

ESC[1;33mFilesESC[0m:
- Test and debug information : ESC[1;37m/var/log/lynis.logESC[0m
- Report data                : ESC[1;37m/var/log/lynis-report.datESC[0m

=====

ESC[1;37mLynisESC[0m 3.0.9

Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)

2007-2021, CISOfy - https://cisofy.com/lynis/
ESC[1;37mEnterprise support available (compliance, plugins, interface and tools)ESC[0m

=====

ESC[0;44m[TIP] ESC[0m: ESC[0;94mEnhance Lynis audits by adding your settings to custom.prfl (see /etc/lynis/default.prfl for all settings)ESC[0m

student@vm2:~$ grep -i warning lynis.txt
- Permissions for directory: /etc/sudoers.d          [ WARNING ]
- Checking vulnerable packages                       [ WARNING ]
- Checking for empty ruleset                         [ WARNING ]
[WARNING]: Test CRYPT-7902 had a long execution: 15.193042 seconds
Warnings (2):
student@vm2:~$ grep -i suggestion lynis.txt
- Password hashing methods                          [ SUGGESTION ]
- PAM password strength tools                       [ SUGGESTION ]
- Accounts without expire date                     [ SUGGESTION ]
- umask (/etc/login.defs)                          [ SUGGESTION ]
- Checking /home mount point                       [ SUGGESTION ]
- Checking /tmp mount point                        [ SUGGESTION ]
- Checking /var mount point                        [ SUGGESTION ]
- Testing /proc mount (hidepid)                    [ SUGGESTION ]
File: /etc/crontab                                 [ SUGGESTION ]
File: /etc/ssh/sshd_config                         [ SUGGESTION ]
Directory: /etc/cron.d                             [ SUGGESTION ]
Directory: /etc/cron.daily                         [ SUGGESTION ]
Directory: /etc/cron.hourly                       [ SUGGESTION ]
Directory: /etc/cron.weekly                       [ SUGGESTION ]
Directory: /etc/cron.monthly                      [ SUGGESTION ]
Suggestions (40):
student@vm2:~$

```

Keskeisimmät kehitysehdotukset liittyivät:

- salasanojen vahvuuden parantamiseen
- PAM-salasanahallinnan käyttöönottoon
- käyttäjätilien vanhenemisasetusten tarkistamiseen
- SSH-palvelimen asetusten koventamiseen
- tiedostojärjestelmän suojausasetuksiin
- ajastettujen tehtävien (cron) käyttöoikeuksien tarkastamiseen

Tulokset osoittivat, että järjestelmä oli perustoiminnallisuuksiltaan turvallinen, mutta sen suojaustasoa voitaisiin edelleen parantaa toteuttamalla Lyniksen suosittelemia kovennustoimenpiteitä.

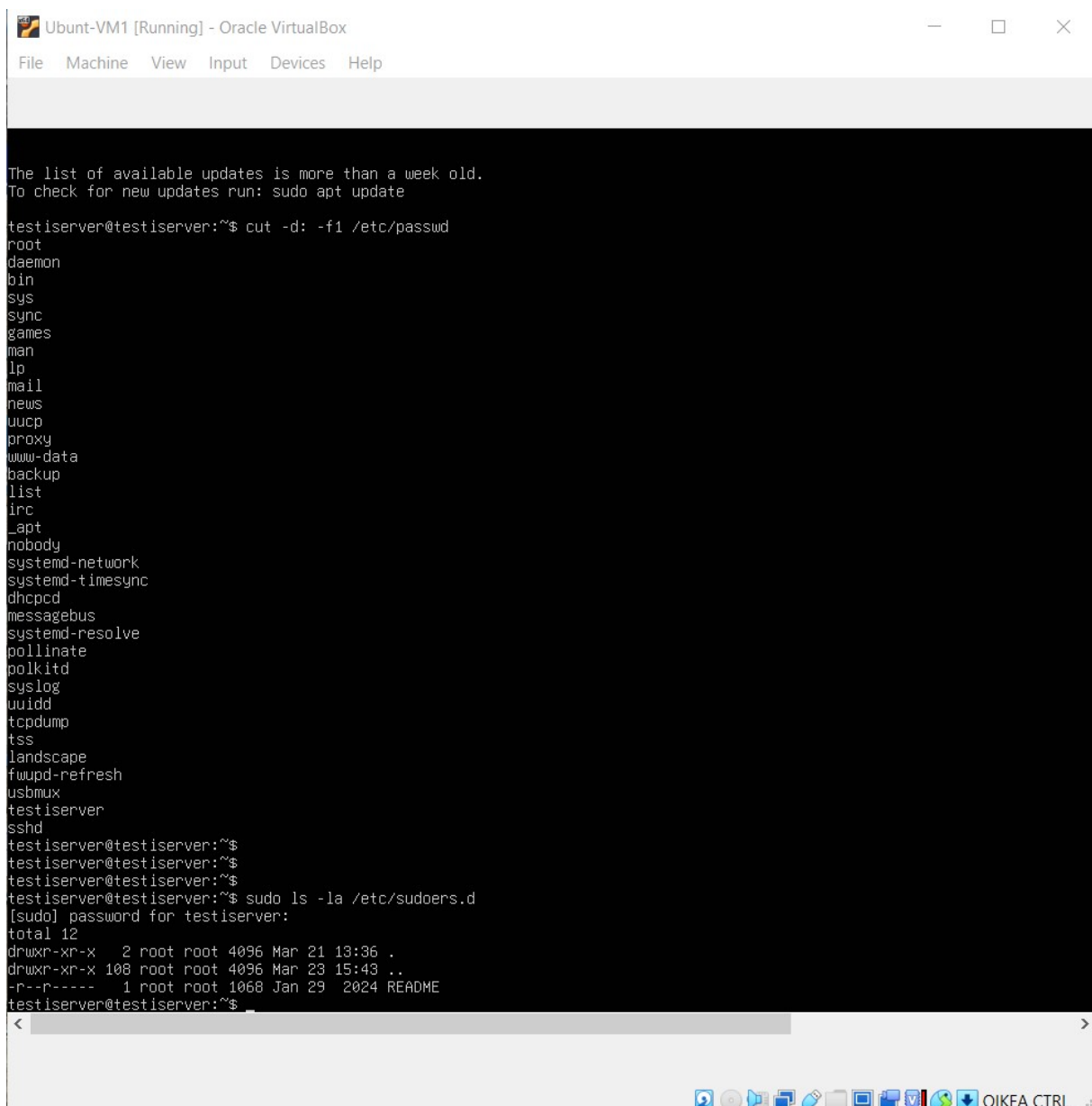
Lynis soveltui hyvin teknisen auditoinnin työkaluksi, sillä se tarjosi nopeasti yleiskuvan järjestelmän tietoturvan tilasta. Työkalun avulla tunnistettiin useita sellaisia asetuksia, joita ei olisi välttämättä havaittu pelkästään verkkoskannauksen avulla. Auditoinnin perusteella järjestelmän merkittävimmät kehityskohteet liittyivät salasanoihin, käyttöoikeuksiin sekä palvelimen koventamiseen.

7.5. Käyttöoikeudet

Käyttöoikeuksien hallinta on yksi tietoturvan keskeisistä osa-alueista. Auditoinnissa tarkasteltiin käyttäjätilien hallintaa sekä järjestelmän käyttöoikeusasetuksia.

Ubuntu Server -järjestelmässä tarkastettiin käyttäjätilit sekä sudo-oikeuksiin liittyvät asetukset. Tarkastelussa varmistettiin, että järjestelmänhallintaan liittyvät tiedostot olivat asianmukaisesti suojattuja.

Kuva 11. sudoers-hakemiston käyttöoikeuksien tarkastelu Ubuntu-palvelimella.



```
Ubuntu-VM1 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

testiserver@testiserver:~$ cut -d: -f1 /etc/passwd
root
daemon
bin
sys
sync
games
man
lp
mail
news
uucp
proxy
www-data
backup
list
irc
_apt
nobody
systemd-network
systemd-timesync
dhcpcd
messagebus
systemd-resolve
pollinate
polkitd
syslog
uucidd
tcpdump
tss
landscape
fwupd-refresh
usbmux
testiserver
sshd
testiserver@testiserver:~$
testiserver@testiserver:~$
testiserver@testiserver:~$
testiserver@testiserver:~$ sudo ls -la /etc/sudoers.d
[sudo] password for testiserver:
total 12
drwxr-xr-x  2 root root 4096 Mar 21 13:36 .
drwxr-xr-x 108 root root 4096 Mar 23 15:43 ..
-r--r----- 1 root root 1068 Jan 29  2024 README
testiserver@testiserver:~$
```


Lynis-auditointi nosti esiin käyttöoikeuksiin liittyviä tarkastuskohteita erityisesti /etc/sudoers.d -hakemiston osalta. Vakavia käyttöoikeuspoikkeamia ei kuitenkaan havaittu.

Tulosten perusteella käyttöoikeuksien hallinta oli perustasolla kunnossa, mutta käyttöoikeuksia tulisi tarkastella säännöllisesti sekä noudattaa vähimpien oikeuksien periaatetta.

7.6. Lokitus ja valvonta

Lokituksen avulla voidaan seurata järjestelmän tapahtumia sekä havaita mahdollisia tietoturvapoikkeamia. Auditoinnin aikana tarkasteltiin Ubuntu Server -järjestelmän lokitietoja journalctl-työkalulla.

Lokitiedoista tarkasteltiin erityisesti käyttäjien kirjautumisia, järjestelmäpalveluiden käynnistymisiä sekä ylläpitotoimenpiteitä. Tarkastelussa havaittiin, että järjestelmä tallensi onnistuneita kirjautumisia, sudo-komentojen käyttöä sekä palveluiden toimintaan liittyviä tapahtumia.

Kuva 12. Ubuntu-palvelimen lokitietojen tarkastelu journalctl-työkalulla.

```

lirc
lapt
nobody
systemd-network
systemd-timesync
dhcpd
messagebus
systemd-resolve
pollinate
polkitd
syslog
uidd
tcpdump
tss
landscape
fiupd-refresh
usbmux
testiserver
sshd
testiserver@testiserver:~$
testiserver@testiserver:~$
testiserver@testiserver:~$
testiserver@testiserver:~$ sudo ls -la /etc/sudoers.d
[sudo] password for testiserver:
total 12
drwxr-xr-x  2 root root 4096 Mar 21 13:36 .
drwxr-xr-x 108 root root 4096 Mar 23 15:43 ..
-r--r--r--  1 root root 1068 Jan 29 2024 README
testiserver@testiserver:~$ journalctl -n 20
Jun 03 18:02:55 testiserver systemd[1095]: Reached target default.target - Main User Target.
Jun 03 18:02:55 testiserver systemd[1]: Started user@1000.service - User Manager for UID 1000.
Jun 03 18:02:55 testiserver systemd[1095]: Startup finished in 562ms.
Jun 03 18:02:55 testiserver systemd[1]: Started session-1.scope - Session 1 of User testiserver.
Jun 03 18:04:40 testiserver systemd[1]: Starting update-notifier-download.service - Download data for packages that failed at package install time...
Jun 03 18:04:40 testiserver systemd[1]: update-notifier-download.service: Deactivated successfully.
Jun 03 18:04:40 testiserver systemd[1]: Finished update-notifier-download.service - Download data for packages that failed at package install time.
Jun 03 18:05:01 testiserver CRON[1158]: pam_unix(cron:session): session opened for user root(uid=0) by root(uid=0)
Jun 03 18:05:01 testiserver CRON[1159]: (root) CMD (command -v debian-sa1 > /dev/null && debian-sa1 1 1)
Jun 03 18:05:01 testiserver pam_unix(cron:session): session closed for user root
Jun 03 18:06:08 testiserver systemd[1]: Starting fstrim.service - Discard unused blocks on filesystems from /etc/fstab...
Jun 03 18:06:08 testiserver systemd[1]: fstrim.service: Deactivated successfully.
Jun 03 18:06:08 testiserver systemd[1]: Finished fstrim.service - Discard unused blocks on filesystems from /etc/fstab.
Jun 03 18:06:10 testiserver systemd[1095]: launchpadlib-cache-clean.service - Clean up old files in the Launchpadlib cache was skipped because of an unmet condition
Jun 03 18:06:58 testiserver sudo[1166]: testiserver : TTY=ttty ; PWD=/home/testiserver ; USER=root ; COMMAND=/usr/bin/ls -la /etc/sudoers.d
Jun 03 18:06:58 testiserver sudo[1166]: pam_unix(sudo:session): session opened for user root(uid=0) by testiserver(uid=1000)
Jun 03 18:06:58 testiserver sudo[1166]: pam_unix(sudo:session): session closed for user root
Jun 03 18:10:18 testiserver systemd[1]: Starting sysstat-collect.service - system activity accounting tool...
Jun 03 18:10:18 testiserver systemd[1]: sysstat-collect.service: Deactivated successfully.
Jun 03 18:10:18 testiserver systemd[1]: Finished sysstat-collect.service - system activity accounting tool.
lines 1-20/20 (END)

```

Tulosten perusteella lokitus oli käytössä ja tuotti hyödyllistä tietoa järjestelmän tapahtumista. Lokit mahdollistavat jälkikäteisen analysoinnin esimerkiksi tietoturvapoikkeamien tai virhetilanteiden yhteydessä. Pk-yritysympäristössä lokien säännöllinen seuranta sekä keskitetty lokienhallinta voivat merkittävästi parantaa kykyä havaita poikkeavaa toimintaa.

7.7. Varausuminen kiristyshaittaohjelmiin

Kiristyshaittaohjelmat ovat yksi merkittävimmistä nykyisistä kyberturvallisuushista. Tämän vuoksi auditoinnissa arvioitiin myös organisaation valmiuksia suojautua kiristyshaittaohjelmia vastaan.

Arvioinnissa huomioitiin erityisesti seuraavia osa-alueita:

- ohjelmistopäivitysten ajantasaisuus
- varmuuskopiointimenettelyt
- käyttöoikeuksien hallinta
- käyttäjätunnusten suojaaminen
- lokitus ja valvonta

Tulosten perusteella ympäristön perustason suojaus oli kunnossa. Järjestelmä oli päivitetty, tarpeettomia verkkopalveluita ei havaittu ja lokitus oli käytössä. Kehityskohteina tunnistettiin salasanojen vahvistaminen, käyttöoikeuksien säännöllinen tarkastaminen sekä varmuuskopiointikäytäntöjen edelleen kehittäminen.

Kiristyshaittaohjelmiin varautuminen edellyttää teknisten suojaustoimien lisäksi henkilöstön koulutusta, selkeitä toimintamalleja sekä säännöllisesti testattuja palautusmenettelyjä.

8. Analyysi ja suositukset

8.1. Löydösten vertailu hallinnollisiin vaatimuksiin

Auditoinnin teknisiä havaintoja verrattiin työn alkuvaiheessa laadittuun hallinnolliseen ja tekniseen tarkistuslistaan sekä valittuihin viitekehyksiin (Traficom/Kyberturvallisuuskeskus, ISO/IEC 27001 ja NIST Cybersecurity Framework).

POC-ympäristössä toteutetut tarkastukset osoittivat, että järjestelmän perusasetukset olivat pääosin tietoturvan kannalta tarkoituksenmukaisia. Nmap-porttiskannauksen perusteella kohdejärjestelmässä oli avoinna vain ympäristön toiminnan kannalta tarvittavat palvelut (SSH ja HTTP), mikä tukee vähimmän palveluallistuksen periaatetta.

Käyttäjähallinnan tarkastuksessa varmistettiin käyttäjätilien olemassaolo sekä sudo-oikeuksien hallinta. Tarkastuksessa ei havaittu poikkeavia käyttöoikeuksia tai ylimääräisiä järjestelmänvalvojan oikeuksia sisältäviä käyttäjätilejä.

Lynis-auditointityökalun avulla tunnistettiin useita järjestelmän kovennukseen liittyviä kehityskohteita. Vaikka ympäristö oli tarkoitettu ensisijaisesti testikäyttöön, tulokset osoittivat, että järjestelmää voidaan edelleen vahvistaa esimerkiksi palveluiden, lokituksen ja käyttöoikeuksien hallinnan osalta.

OpenVAS/GVM-ympäristön käyttöönotto onnistui ja työkalun toimivuus varmistettiin. Tämä tukee viitekehysten mukaista jatkuvaa haavoittuvuuksien tunnistamista ja riskienhallintaa. Varsinaista laajaa haavoittuvuusskannausta ei toteutettu osana tätä harjoittelua, mutta ympäristö rakennettiin valmiiksi myöhempiä tarkastuksia varten.

Kokonaisuutena auditoinnin havainnot olivat linjassa valittujen viitekehysten keskeisten tavoitteiden kanssa. Erityisesti järjestelmän näkyvyyden, palveluiden hallinnan, käyttöoikeuksien tarkastamisen sekä teknisen auditointikyvykkyyden voidaan katsoa toteutuneen onnistuneesti harjoittelun aikana.

8.2. Keskeiset vahvuudet ja puutteet

Auditoinnin perusteella POC-ympäristö täytti sille asetetut tavoitteet ja mahdollisti keskeisten tietoturvatarkastusten suorittamisen. Ympäristössä havaittiin useita vahvuuksia, mutta myös kehityskohteita, jotka ovat tyypillisiä järjestelmien tietoturvan jatkuvassa parantamisessa.

Vahvuudet

Ympäristö rakennettiin onnistuneesti kahden virtuaalikoneen kokonaisuutena, jossa auditointikone ja kohdejärjestelmä olivat eriytettyinä omiin rooleihinsa. Tämä mahdollisti realistisen auditointitilanteen simuloinnin.

Nmap-porttiskannauksen perusteella kohdejärjestelmässä oli avoinna vain toiminnan kannalta välttämättömät palvelut. Tämä vähentää hyökkäyspinta-alaa ja tukee tietoturvan parhaita käytäntöjä.

Käyttäjähallinnan tarkastuksissa ei havaittu ylimääräisiä järjestelmänvalvojan oikeuksia sisältäviä käyttäjätilejä. Lisäksi sudo-oikeuksien hallinta oli toteutettu järjestelmän oletuskäytäntöjen mukaisesti.

Lynis-auditointityökalu sekä OpenVAS/GVM-ympäristö saatiin käyttöön onnistuneesti. Tämä osoittaa, että ympäristö soveltuu teknisten tietoturva-auditointien toteuttamiseen ja jatkokehittämiseen.

Lokitietojen tarkastaminen onnistui, mikä tukee järjestelmän valvontaa, tapahtumien seurantaan sekä mahdollisten poikkeamien tutkimista.

Puutteet ja kehityskohteet

Lynis-auditointi tunnisti useita järjestelmän kovennukseen liittyviä kehityskohteita. Vaikka havaitut puutteet eivät olleet kriittisiä, ne osoittivat mahdollisuuksia parantaa järjestelmän suojaustasoa.

OpenVAS/GVM-ympäristö saatiin asennettua ja toimintakuntoon, mutta varsinaista laajamittaista haavoittuvuusskannausta ei toteutettu harjoittelun aikana. Jatkossa työkalua voidaan hyödyntää syvällisempään haavoittuvuuksien kartoittamiseen.

POC-ympäristö oli rajattu laboratorioympäristö, eikä siinä tarkasteltu esimerkiksi organisaation käyttäjien toimintatapoja, hallinnollisia prosesseja tai tuotantoympäristöjen erityisvaatimuksia. Tämän vuoksi tulokset kuvaavat ensisijaisesti teknisen auditointimallin toimivuutta.

Auditoinnin aikana tunnistettiin myös tarve jatkuvalle järjestelmäpäivitysten seurannalle ja tietoturvakonfiguraatioiden säännölliselle tarkastamiselle, jotta ympäristön turvallisuustaso säilyy ajan myötä.

Kokonaisuutena auditoinnin vahvuudet olivat selvästi havaittuja puutteita merkittävämpiä. Rakennettu ympäristö osoitti, että suunniteltu auditointipalvelumalli on teknisesti toteuttamiskelpoinen ja että avoimen lähdekoodin työkaluilla voidaan suorittaa pk-yrityksille soveltuvia tietoturvatarkastuksia kustannustehokkaasti.

8.3. Suositukset pk-yrityksille

Tämän harjoittelun aikana toteutetun auditointimallin perusteella pk-yrityksille voidaan antaa useita käytännön suosituksia tietoturvan kehittämiseksi. Monet tietoturvariskit voidaan tunnistaa ja ehkäistä jo suhteellisen yksinkertaisilla ja kustannustehokkailla toimenpiteillä.

Ensimmäinen suositus on suorittaa säännöllisiä tietoturva-auditointeja. Järjestelmien, palveluiden ja käyttöoikeuksien tarkastaminen auttaa havaitsemaan mahdolliset puutteet ennen kuin ne aiheuttavat tietoturvapoikkeamia. Auditoinnit voidaan toteuttaa vaiheittain hyödyntämällä avoimen lähdekoodin työkaluja, kuten Nmapia, Lynisiä ja OpenVAS/GVM:ää.

Toinen tärkeä suositus on minimoida järjestelmien hyökkäyspinta-ala. Käytössä tulisi olla vain toiminnan kannalta välttämättömät palvelut ja avoimet verkkopalvelut. Tarpeettomat käyttäjätilit, ohjelmistot ja palvelut kannattaa poistaa tai poistaa käytöstä.

Kolmantena suosituksena on huolehtia ohjelmistojen ja käyttöjärjestelmien säännöllisestä päivittämisestä. Päivitykset korjaavat tunnettuja haavoittuvuuksia ja vähentävät riskiä joutua tietoturvahyökkäysten kohteeksi.

Lisäksi käyttöoikeudet tulisi myöntää vähimmän oikeuden periaatteen mukaisesti. Käyttäjille annetaan vain ne oikeudet, joita he tarvitsevat työtehtäviensä suorittamiseen. Järjestelmänvalvojan oikeuksia tulisi käyttää vain silloin, kun se on välttämätöntä.

Lokitietojen kerääminen ja seuranta ovat myös keskeinen osa tietoturvaa. Riittävä lokitus auttaa tunnistamaan poikkeavaa toimintaa ja tukee mahdollisten tietoturvapojikkeamien selvittämistä.

Pk-yritysten kannattaa myös hyödyntää haavoittuvuusskannauksia osana jatkuvaa tietoturvan hallintaa. OpenVAS/GVM:n kaltaisilla työkaluilla voidaan tunnistaa tunnettuja haavoittuvuuksia sekä seurata järjestelmien turvallisuustason kehittymistä ajan myötä.

Lisäksi organisaatioiden tulisi varautua kiristyshaittaohjelmien ja muiden tietoturvapojikkeamien mahdollisuuteen. Tämä edellyttää toimivia varmuuskopioita, palautustestauksia sekä ennalta laadittuja toimintamalleja poikkeustilanteita varten.

Tämän harjoittelun perusteella voidaan todeta, että avoimen lähdekoodin auditointityökalut tarjoavat pk-yrityksille kustannustehokkaan keinon tietoturvan nykytilan arviointiin. Säännöllisesti toteutettuna auditointipalvelumalli tukee riskienhallintaa, parantaa tietoturvan näkyvyyttä ja auttaa organisaatiota kehittämään tietoturvaansa pitkäjänteisesti.

9. Johtopäätökset

9.1. Mitä opin

Harjoittelun aikana perehdyttiin tietoturva-auditoinnin suunnitteluun, toteutukseen ja dokumentointiin sekä hallinnollisesta että teknisestä näkökulmasta. Työn aikana tutustuttiin keskeisiin tietoturvan viitekehyksiin, kuten Traficomien ohjeistuksiin, ISO/IEC 27001 -standardiin sekä NIST Cybersecurity Frameworkiin, joiden pohjalta laadittiin auditointimalli pk-yrityksen tarpeisiin.

Teknisessä osuudessa opittiin rakentamaan eristetty POC-ympäristö virtuaalikoneiden avulla sekä käyttämään tietoturva-auditoinnissa yleisesti hyödynnettäviä työkaluja. Harjoittelun aikana käytettiin muun muassa Nmapia verkkoskannukseen, Lynistä järjestelmän tietoturvatarkastuksiin sekä OpenVAS/GVM-järjestelmää haavoittuvuuksien hallintaan.

Lisäksi harjoittelu kehitti osaamista Linux-järjestelmien hallinnassa, palveluiden konfiguroinnissa, lokitietojen tarkastelussa sekä auditointitulosten

dokumentoinnissa. Kokonaisuutena harjoittelu tarjosi käytännön kokemusta siitä, miten tietoturva-auditointi voidaan suunnitella ja toteuttaa vaiheittain.

9.2. Palvelumallin hyödyt pk-yritykselle

Tämän harjoittelun keskeisenä lopputuloksena muodostui pk-yritykselle soveltuva tietoturva-auditoinnin palvelumalli. Malli yhdistää hallinnollisen tarkastelun, teknisen auditoinnin sekä havaintojen pohjalta laadittavat kehityssuositukset yhdeksi vaiheistetuksi kokonaisuudeksi.

Palvelumallin vahvuutena on sen selkeä rakenne. Auditointi alkaa viitekehysten valinnasta ja tarkistuslistojen laatimisesta, minkä jälkeen siirrytään tekniseen tarkasteluun, havaintojen analysointiin sekä kehitystoimenpiteiden suunnitteluun. Malli soveltuu erityisesti pk-yrityksille, joilla ei välttämättä ole käytettävissään laajoja tietoturvaresursseja.

Harjoittelun aikana toteutettu POC-ympäristö osoitti, että auditointimallia voidaan toteuttaa kustannustehokkaasti avoimen lähdekoodin työkaluilla. Samalla se osoitti, että tietoturvan nykytilaa voidaan arvioida järjestelmällisesti ilman merkittäviä ohjelmistolisenssikustannuksia.

Harjoittelun kolme keskeistä tuotosta olivat:

1. Dokumentoitu tietoturva-auditoinnin palvelumalli pk-yritykselle.
2. Toimiva POC-ympäristö auditointityökaluineen.
3. Auditoinnin havaintoihin perustuva analyysi ja kehityssuositukset.

9.3. Jatkokehitysmahdollisuudet

Työssä rakennettu auditointimalli tarjoaa hyvän perustan jatkokehitykselle. Tulevaisuudessa mallia voitaisiin laajentaa kattamaan suurempia ja monimutkaisempia ympäristöjä, kuten useita palvelimia, työasemia tai pilvipalveluita hyödyntäviä organisaatioita.

Teknisen auditoinnin osalta jatkokehitystä voitaisiin tehdä erityisesti haavoittuvuuksien hallinnan ja valvonnan alueilla. OpenVAS/GVM-järjestelmää voitaisiin hyödyntää laajempien haavoittuvuusskannausten suorittamiseen sekä tulosten jatkuvaan seurantaan. Lisäksi ympäristöön voitaisiin liittää keskitetty lokienhallinta tai tietoturvatapahtumien valvontaratkaisu.

Hallinnollisen auditoinnin näkökulmasta palvelumallia voitaisiin täydentää riskienhallinnan, jatkuvuussuunnittelun sekä henkilöstön tietoturvakoulutuksen

arviointimenetelmillä. Näin auditoinnista muodostuisi entistä kattavampi kokonaisuus.

Kokonaisuutena harjoittelussa rakennettu malli tarjoaa käyttökelpoisen lähtökohdan pk-yritysten tietoturvan arviointiin ja kehittämiseen sekä mahdollistaa auditointien toistamisen yhtenäisellä ja dokumentoidulla tavalla.

Lähteet

Traficom Kyberturvallisuuskeskus. Tietoturvaopas pk-yrityksille.
<https://www.kyberturvallisuuskeskus.fi/fi/ajankohtaista/oppaat-ja-ohjeet>

International Organization for Standardization (ISO). ISO/IEC 27001 Information Security Management.

British Standards Institution (BSI). What is ISO/IEC 27001?

National Institute of Standards and Technology (NIST). Cybersecurity Framework (CSF).
<https://www.nist.gov/cyberframework>

Nmap Project. Nmap Network Security Scanner. <https://nmap.org>

ProjectSecurity. Build a Cybersecurity Homelab: A Practical Guide to Offense + Defense. Teachable-verkkokurssi.

Liitteet

Liite 1 Hallinnollinen tietoturva-auditoinnin checklist

Liite 2 Tietoturva-auditoinnin tekninen checklist

Liite 3 Auditointisuunnitelma

Liite 4 Viitekehysten kartoitus